



Information Security Management System (ISMS)

Part 2

Principles of Information Security Management

- The extended characteristics of information security are known as **the six P's**
 - Planning
 - Policy
 - Programs
 - Protection
 - People
 - Project Management

Planning

- Planning as part of InfoSec management
- Included in the InfoSec planning model
 - **Activities necessary to support the design, creation, and implementation of information security strategies**

Planning (cont'd.)

- **Types of InfoSec plans**
 - **Incident response** planning
 - **Business continuity** planning
 - **Disaster recovery** planning
 - **Policy** planning
 - **Personnel** planning
 - **Technology** rollout planning
 - **Risk management** planning
 - **Security program** planning
 - includes **education, training** and **awareness**

Policy

The set of organizational guidelines that dictates certain behavior within the organization

- Three general categories of policy
 - Enterprise information security policy (EISP)
 - Issue-specific security policy (ISSP)
 - System-specific policies (SysSPs)

Programs

InfoSec operations that are specifically managed as separate entities

- Example: a security education training and awareness (SETA) program
- Other types of programs
 - Physical security program
 - complete with fire, physical access, gates, guards, etc.

Protection

- Executed through risk management activities
 - Including risk assessment and **control**, protection mechanisms, technologies, and tools
 - Each of these mechanisms **represents some aspect of the management of specific controls in the overall information security plan**

People

- The most critical link in the information security program
- Managers must **recognize the crucial role that people play in the information security program**
- This area of InfoSec includes security personnel and the security of personnel, as well as aspects of a SETA program

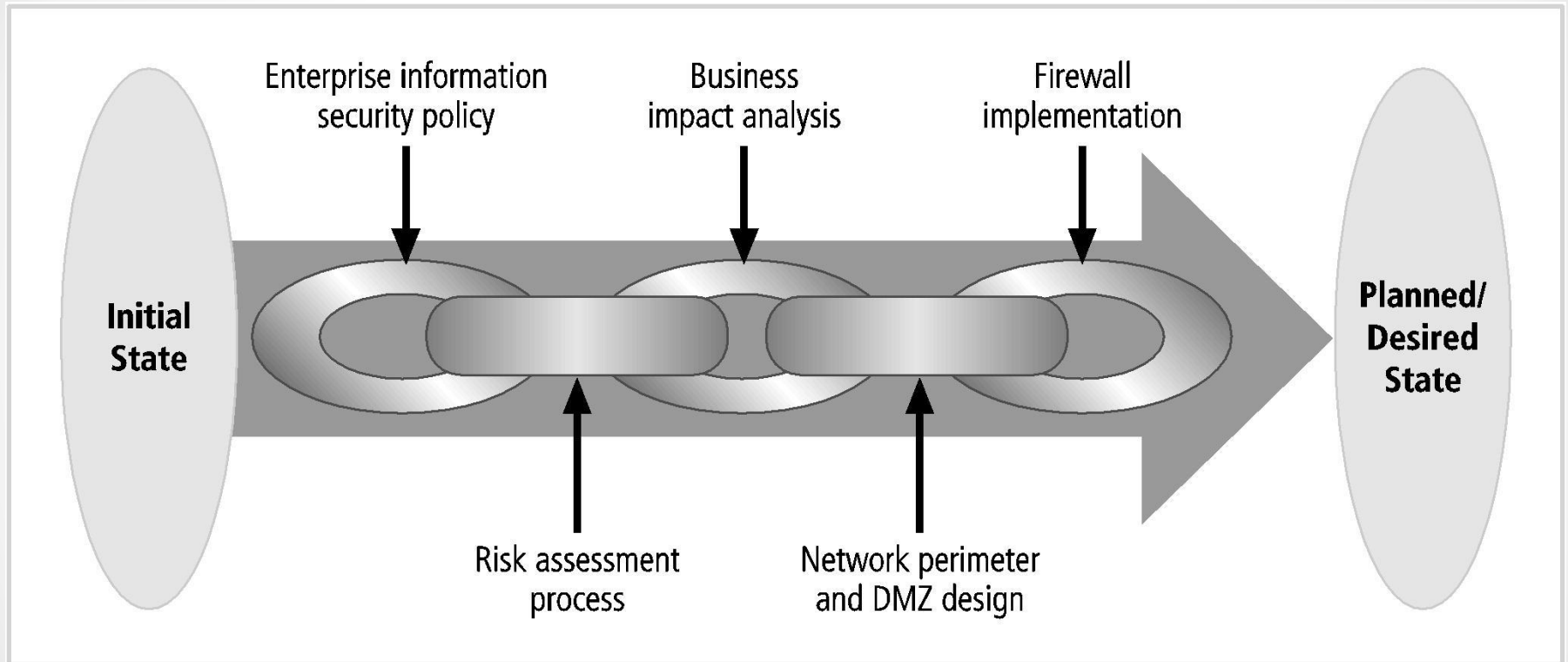
Project Management

- Identifying and controlling the resources applied to the project
- Measuring progress
- Adjusting the process as progress is made

Project Management (cont'd.)

- Each element of an information security program must be managed as a project
- A continuous series, or chain, of projects
- **Some aspects of information security are not project-based**
 - They are managed processes (operations)

Project Management (cont'd.)



The information security program chain

Project Management (cont'd.)

- **Project Management**

- The application of knowledge, skills, tools, and techniques to project activities to meet project requirements
- Accomplished through the use of processes
 - Such as initiating, planning, executing, controlling, and closing
- Involves the temporary assemblage resources to complete a project
- Some projects are iterative, occurring regularly

Managing information boundaries

- Intranet connections to other business units,
- Extranets to business partners,
- Remote connections to staff working off-site,
- Virtual Private Networks (VPN's),
- Customer networks,
- Supplier chains,
- Service Level Agreements, contracts, outsourcing arrangements,
- Third Party access.



Context for Info Security Management

